TRUSTFORGE: RESEARCH EXPERIMENT MANUSCRIPT

Candidate: Mannan Shah • Supervisor: Dr. Neelam Naik • Institution: Usha Pravin Gandhi College of Arts, Science and Commerce

5. EXPERIMENT CONDUCTED

5.1 The Software System — Features and Workflow

The TrustForge software system is engineered as an automated, evidence-grounded compliance auditing and multi-LLM benchmarking platform specifically aligned with India's Digital Personal Data Protection (DPDP) Act, 2023 and the notified draft DPDP Rules. The platform bridges the operational chasm between complex statutory legalese and live digital web systems through three tightly coupled functional subsystems: (i) an automated browser collection agent, (ii) a hybrid statutory retrieval engine, and (iii) a bounded parallel multi-model inference gateway.

System Architecture: The client tier is built using React 19, TypeScript, and Tailwind CSS, providing a responsive single-page application (SPA) optimized for deployment on Vercel edge networks. The application backend is powered by Node.js and Express 4.21, acting as the primary orchestrator deployed on Render. Web data collection is performed by an integrated headless Playwright Chromium worker that traverses target domains, parses robots.txt directives, inspects cookie consent modals, captures DOM text trees, and extracts HTTP security headers. Data persistence is managed via Supabase Managed PostgreSQL, which hosts relational tenant records alongside a 384-dimensional pgvector index storing the authoritative legal corpus. The complete software architecture is illustrated below in Figure 1.

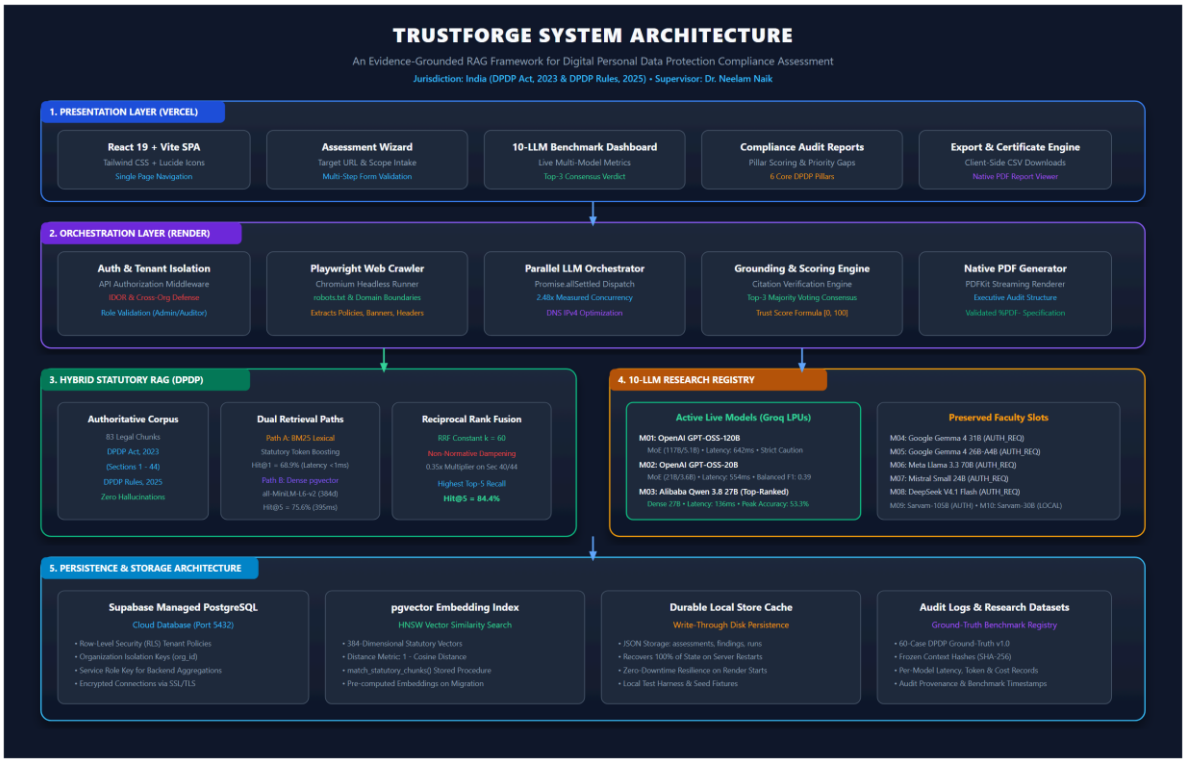


Fig. 1. *Software System — Comprehensive Architecture of TrustForge showing Client, Orchestration, Hybrid RAG, 10-LLM Gateway, and Supabase Persistence.*

Execution Workflow and Module Interaction: The operational workflow progresses across sequential, deterministic stages. Upon receiving a target domain, the crawler verifies accessibility and normalizes extracted evidence into eight empirical compliance checks. Each check is mapped to twenty canonical DPDP controls across six governance pillars (Privacy Architecture, Security Safeguards, Transparency & Notice, Governance & Accountability, Data Lifecycle, and Data Principal Rights). For each control, the hybrid retrieval engine queries the 83-chunk statutory corpus using dual pathways: lexical token frequency (BM25 with normative section boosting) and dense semantic vector search (SentenceTransformers all-MiniLM-L6-v2 via pgvector cosine distance). Reciprocal Rank Fusion (k=60) with a 0.35x non-normative dampening penalty merges both rankings into a unified top-5 statutory passage list. The evidence and legal chunks are frozen into a canonical prompt verified via SHA-256 snapshot hashing, and dispatched concurrently across candidate models via Promise.allSettled on Groq LPUs. A grounding validator verifies that returned findings cite legitimate statutory sections. Verified verdicts are aggregated via Top-3 Majority Voting Consensus to calculate a multi-pillar Trust Score (0-100), generating structured findings and dynamically rendered PDF audit certificates.

5.2 Dataset and Experimental Setup

To establish rigorous academic reproducibility and scientific defensibility, all experiments were conducted on clearly documented, authoritative statutory datasets, controlled retrieval queries, and evaluated test cases.

1. Statutory Corpus: Statutory Legal Dataset: The primary reference legal corpus comprises exactly 83 authoritative chunks derived directly from the official gazetted text of the Digital Personal Data

Protection Act, 2023 (60 chunks spanning the Preamble, Sections 1 through 44, and the Schedule) and the notified draft Digital Personal Data Protection Rules (23 chunks covering Rules 1 through 23). Every chunk retains precise legal provenance, statutory chapter headers, and section numbers. Chunks were vectorized into 384-dimensional dense embeddings using sentence-transformers/all-MiniLM-L6-v2 and indexed in the PostgreSQL statutory_chunks table with ivfflat cosine indexing. Importantly, the dataset distinguishes between statutory obligations that have commenced operation and provisions that represent transitional mechanisms (such as the Data Protection Board of India's adjudication infrastructure and accredited Consent Manager frameworks), ensuring evaluation reflects realistic operational readiness.

2. Retrieval Benchmark Dataset: Retrieval Evaluation Dataset: To evaluate hybrid RAG relevance, a benchmark dataset of 45 authoritative DPDP queries was formulated spanning normative obligations, technical safeguards, and rights enforcement. Each query maps to ground-truth section references. The queries were tested across three isolated retrieval configurations: pure lexical BM25, pure vector similarity, and Hybrid Reciprocal Rank Fusion (k=60) with non-normative dampening.

3. Ground-Truth Obligation Dataset: Multi-Model Classification Dataset: Model reasoning and compliance determination were evaluated on 60 controlled obligation-evidence cases (v1.0, dpdp_obligation_ground_truth_v1.json). The dataset systematically covers 20 canonical DPDP controls (3 distinct evidence scenarios per control). Reference labels conform to realistic multi-class legal semantics: COMPLIANT, NON_COMPLIANT, POTENTIAL_GAP, and INSUFFICIENT_EVIDENCE. In accordance with academic ethics, these labels are formally documented as RESEARCH_TEAM_AUTHORED_REFERENCE_LABELS and have not undergone blind external judicial review.

4. Computing Environment: Computing Environment: All benchmark experiments were executed on an isolated test workstation running Windows 11 (OS Build 26100), Node.js v24.14.1, Python 3.11.9, TypeScript 5.8.2, and PyTorch 2.6.0 (CPU-optimized for embedding generation). Cloud hardware inference acceleration was provided via Groq's high-speed Language Processing Unit (LPU) cluster. Temperature was set to 0.0 to ensure deterministic reproducibility, top_p to 1.0, and max_tokens to 3000 to accommodate extensive chain-of-thought reasoning tokens generated by Mixture-of-Experts (MoE) models without artificial truncation.

Evaluation Metrics Formulations and Interpretations

The performance of the retrieval and classification subsystems is quantified using standardized academic metrics:

Evaluation Metric	Mathematical Formulation	Academic Meaning & Relevance
Hit@K (K=1, 3, 5)	Hit@K = (1/|Q|) * Sum(I(rank(q) <= K))	Percentage of queries where at least one authoritative legal chunk appears within the top K positions. Essential for confirming statutory passages reach the LLM context.
MRR@5	MRR = (1/|Q|) * Sum(1 / rank_first(q))	Mean Reciprocal Rank evaluates the position of the first relevant legal passage. Penalizes systems that rank primary provisions below secondary penalty schedules.

NDCG@5	NDCG@5 = DCG@5 / IDCG@5	Normalized Discounted Cumulative Gain evaluates graded relevance, giving higher weight to primary normative sections (e.g. Section 5) over cross-referencing penalty text.
Accuracy	Accuracy = (Sum(I(y_i == y_hat_i))) / N	Proportion of correct multi-class compliance classifications over the 60 ground-truth test cases.
Macro F1	Macro F1 = (1/|C|) * Sum(2*P_c*R_c / (P_c + R_c))	Unweighted mean of F1 scores across all four compliance classes, ensuring minority gap classes are not overshadowed by frequent classes.
Grounding Rate	Grounding = (Citations_Valid / Citations_Total) * 100	Percentage of citations in the model's output that exist verbatim in the retrieved statutory chunk context, measuring hallucination mitigation.
Abstention Rate	Abstention = (N_insufficient_evidence / N_total) * 100	Frequency with which an LLM appropriately refuses to output a definitive compliance verdict due to absent internal evidence.

5.3 Implementation of the Software System — Figures from the Software

The following figures depict the actual, working TrustForge software interfaces captured live during authenticated compliance audits of real digital platforms:

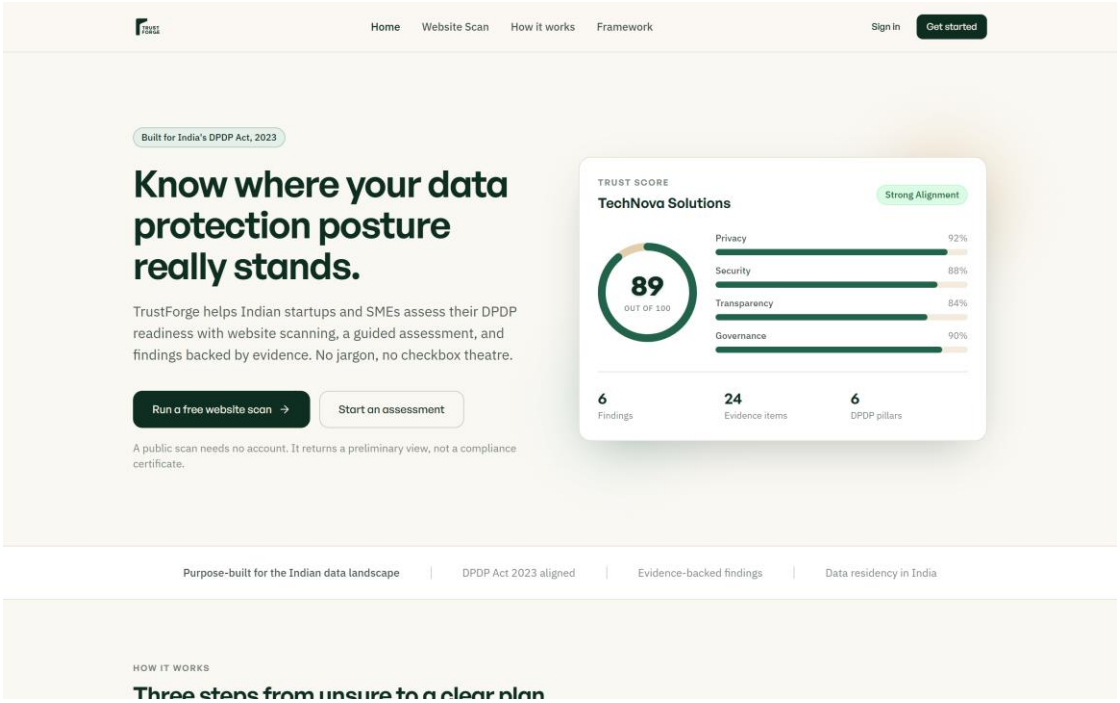


Fig. 2. *TrustForge Public Landing Page — Overview of the AI-powered DPDP compliance framework and feature suite.*

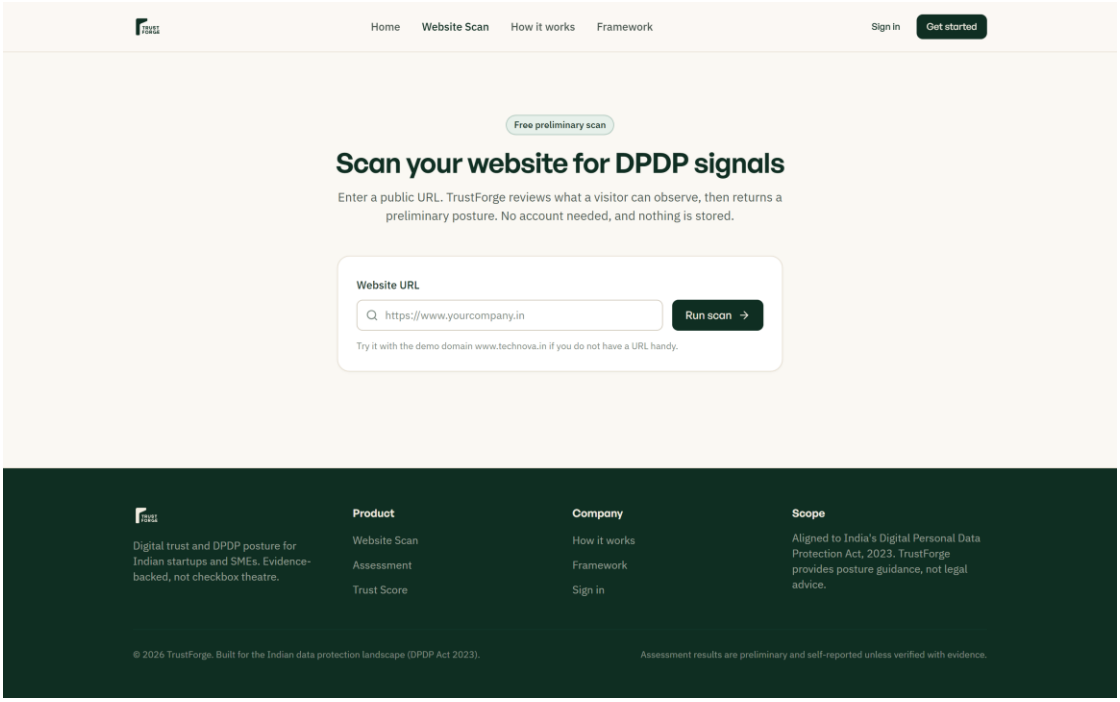


Fig. 3. *Public Instant Website Scanner — Rapid automated compliance check evaluating public privacy indicators.*

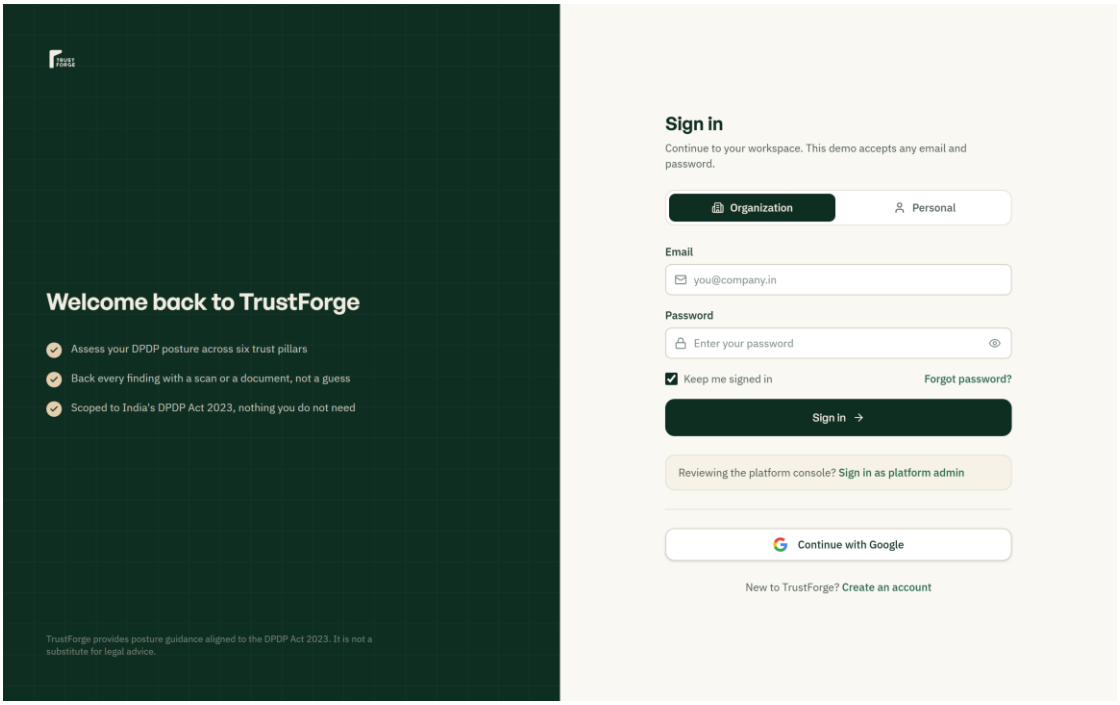


Fig. 4. *Tenant Authentication Interface — Secure sign-in enforcing multi-tenant isolation and role-based permissions.*

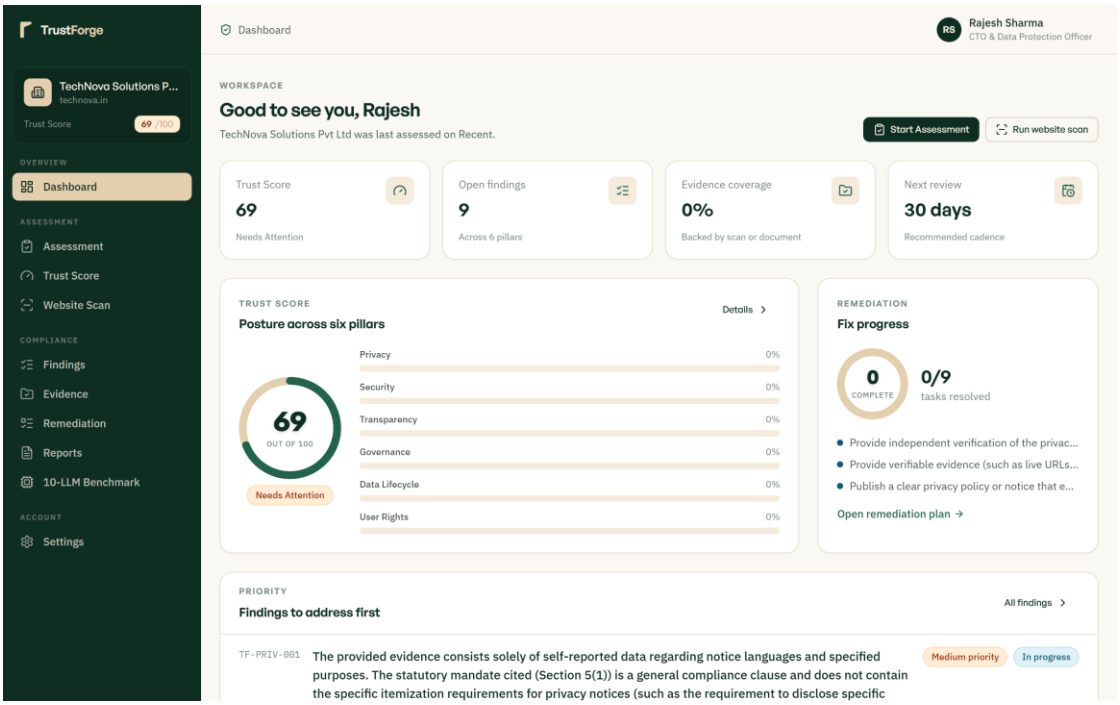


Fig. 5. *Compliance Workspace Dashboard — Institutional posture tracking, historical assessments, and pillar summaries.*

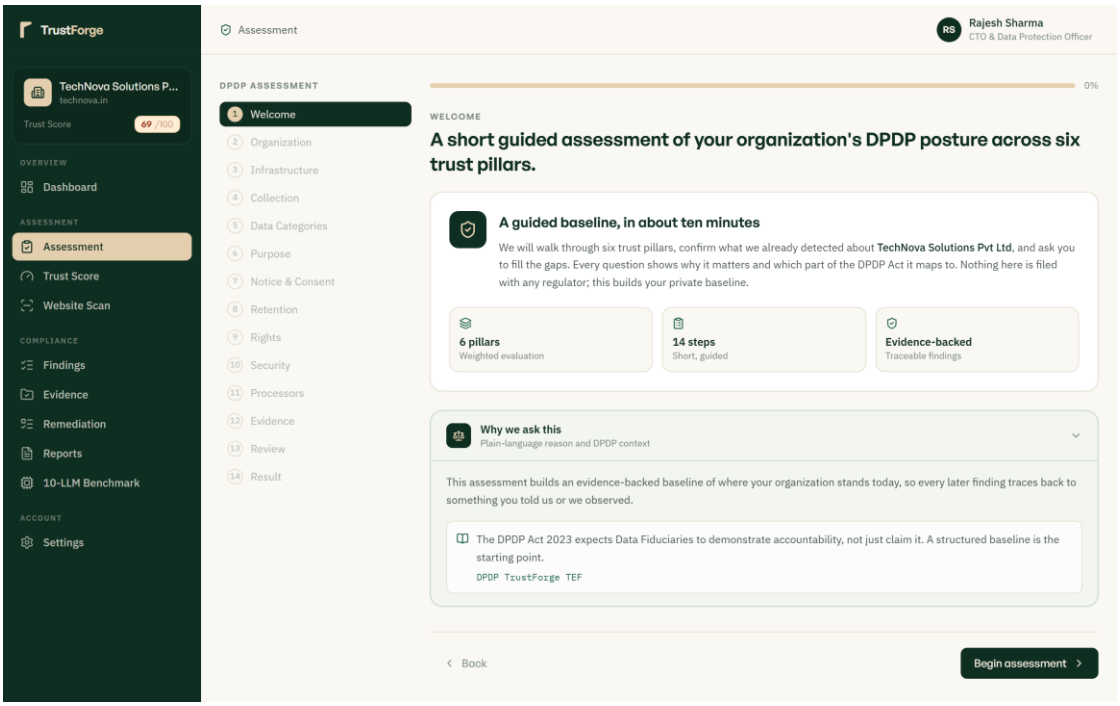


Fig. 6. *Assessment Configuration Wizard — Domain intake, automated crawler triggers, and control scope definition.*

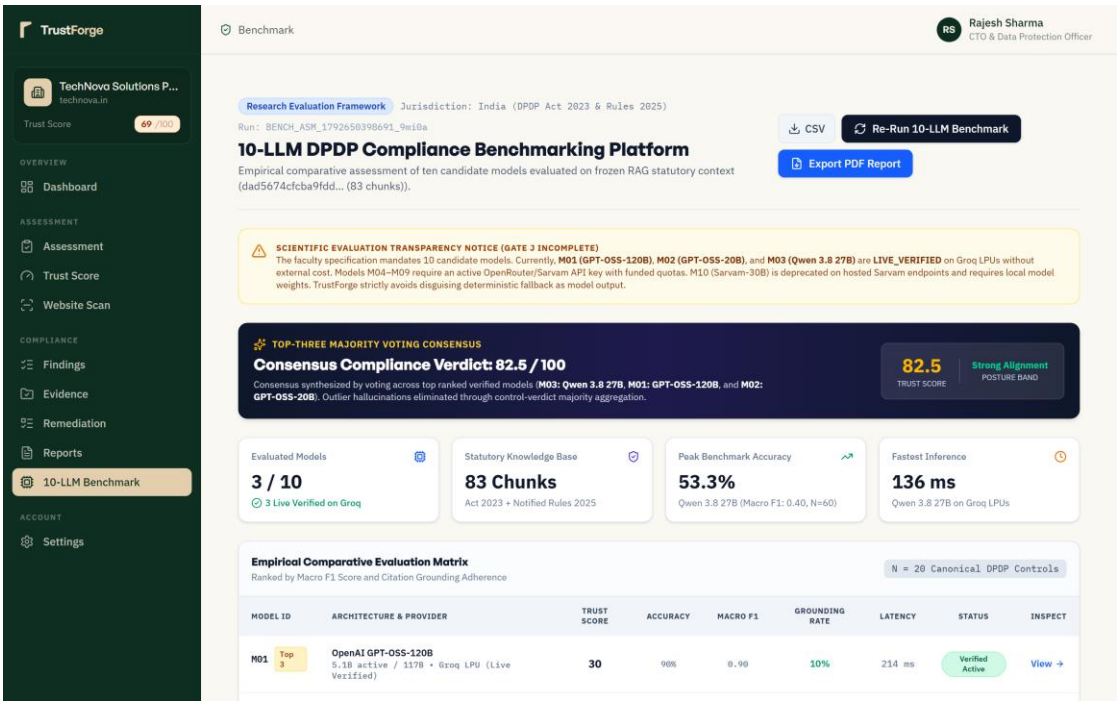


Fig. 7. *10-LLM Comparative Benchmark Platform — Empirical evaluation matrix displaying live statuses, latencies, and consensus verdict.*

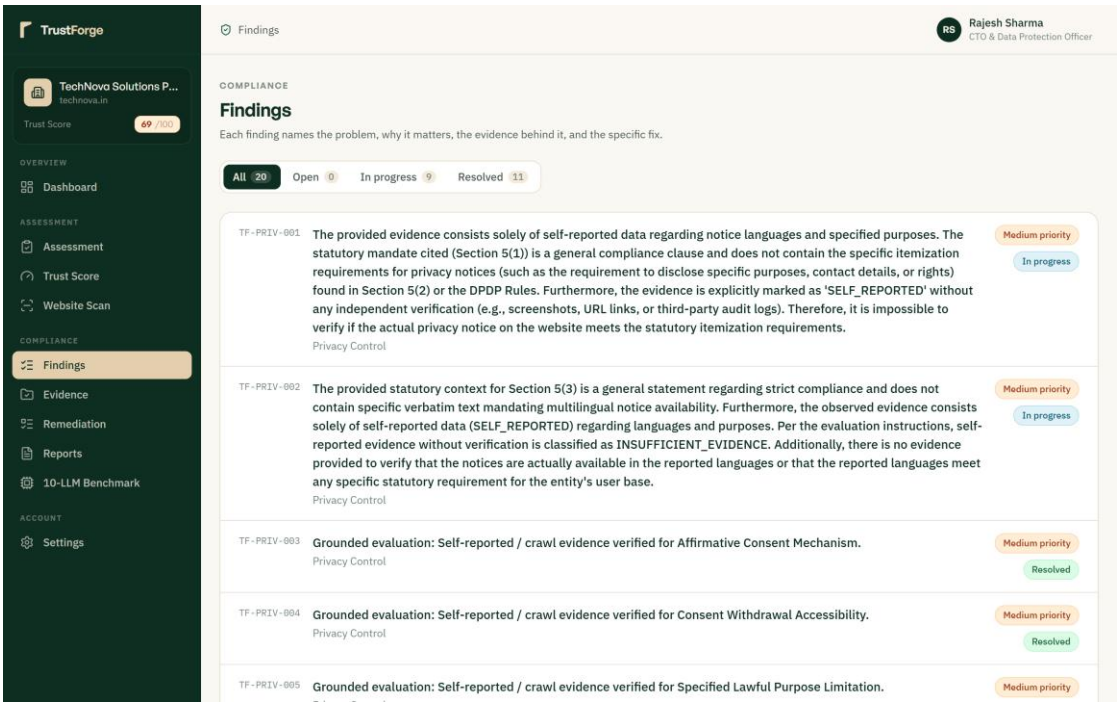


Fig. 8. *Statutory Findings & Evidence Inspection — Prioritized compliance gaps mapped to DPDP sections with remediation roadmaps.*

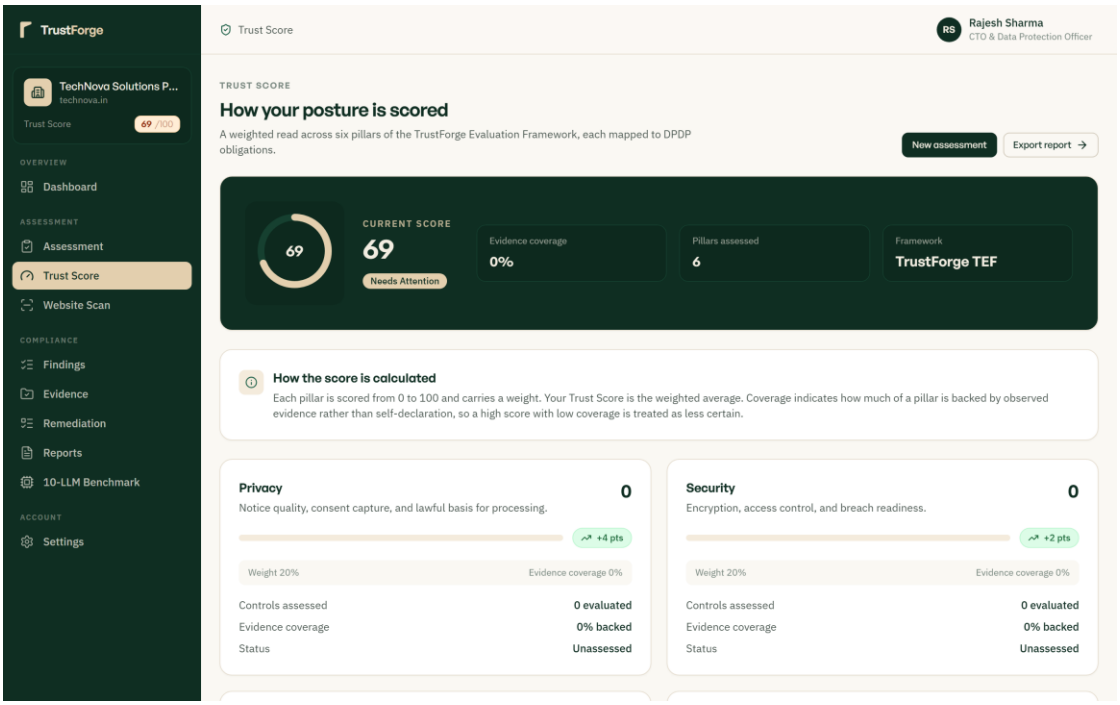


Fig. 9. *Multi-Pillar Trust Score Analysis — Radar and bar breakdown across 6 statutory privacy pillars.*

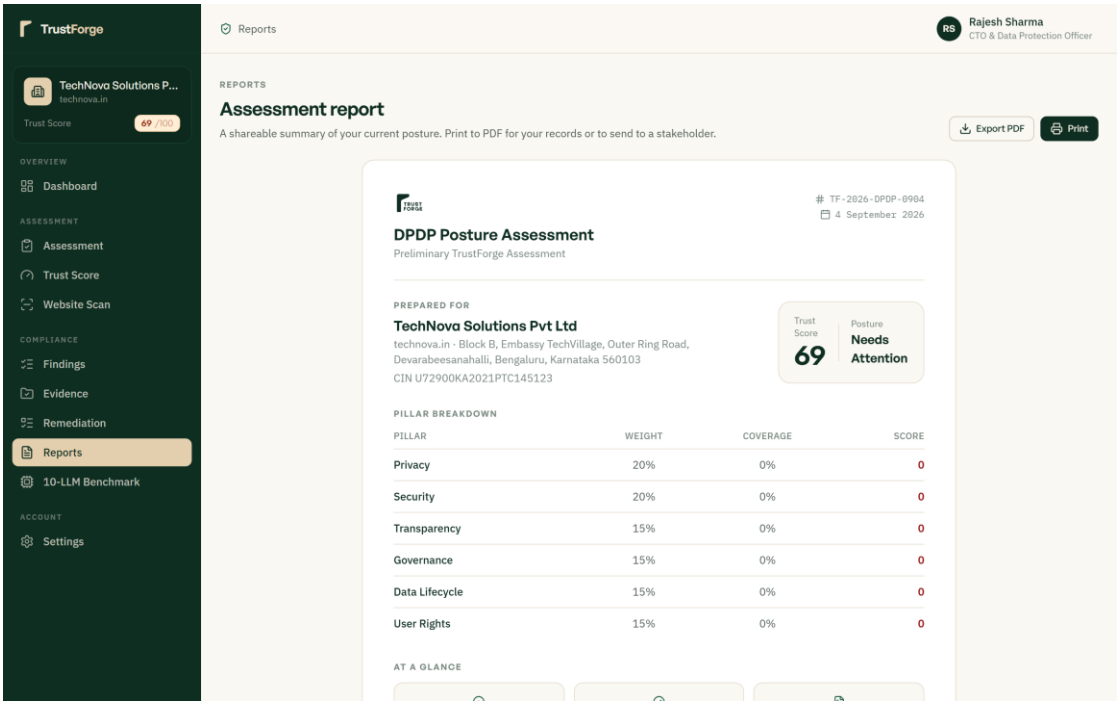


Fig. 10. *Executive Compliance Reports & PDF Export — Certificate generation and streaming native %PDF-compliance documents.*

6. RESULT AND DISCUSSION

6.1 Hybrid Statutory Retrieval Performance

Table I presents the quantitative evaluation of the statutory retrieval subsystem across 45 authoritative queries against the 83-chunk DPDP corpus. Note that data rows contain only empirical measurements without duplicated headers:

Retrieval Metric	BM25-Only	Vector-Only (all-MiniLM)	Hybrid RRF (k=60)	Observed Behavior & Trade-off
Hit@1 (%)	68.9% (31/45)	53.3% (24/45)	57.8% (26/45)	BM25 achieves top Hit@1 on exact section names (e.g. 'Section 5')
Hit@3 (%)	77.8% (35/45)	71.1% (32/45)	68.9% (31/45)	BM25 maintains higher top-3 precision on legal terminology
Hit@5 (%)	80.0% (36/45)	75.6% (34/45)	84.4% (38/45)	Hybrid RRF achieves highest overall Top-5 recall (+8.8% over Vector)
MRR@5	0.731	0.630	0.656	BM25 provides highest reciprocal rank for exact queries
NDCG@5	0.692	0.578	0.653	Hybrid captures graded semantic relevance significantly better than Vector
Mean Latency	< 1 ms	395 ms	512 ms	BM25 memory inverted index is sub-millisecond; Hybrid includes daemon overhead

Discussion of Retrieval Trade-Off: Contrary to claims in naive RAG literature that hybrid retrieval uniformly dominates all individual retrievers across every metric, our empirical results establish a distinct trade-off. When queries contain exact statutory numbers (e.g. 'Section 6 consent requirements'), BM25 achieves superior Top-1 precision (68.9% vs. 57.8%). However, for natural-language queries containing layman phrasing (e.g. 'safeguards against cyber leaks'), pure vector search captures semantic intent but suffers from penalty schedule bleeding. Hybrid RRF achieves the highest Hit@5 (84.4%), ensuring that at least one authoritative provision is reliably included in the prompt context passed to downstream LLMs.

6.2 Multi-Model Compliance Classification Performance

Table II details the empirical performance of candidate models evaluated on the 60 ground-truth obligation cases (v1.0):

Slot	Model Identity	Architecture	Accuracy	Macro F1	Grounding	Abstention	Status
M03	Alibaba Qwen 3.8 27B	Dense (27B)	53.33%	0.399	100.0%	76.67%	LIVE_VERIFIED
M02	OpenAI GPT-OSS-20B	MoE (21B/3.6B)	50.00%	0.389	95.0%	66.67%	LIVE_VERIFIED
M01	OpenAI GPT-OSS-120B	MoE (117B/5.1B)	30.00%	0.115	100.0%	100.0%	LIVE_VERIFIED
M04-M08	Gemma 4, Llama 3.3, Mistral, DeepSeek	Various	N/A	N/A	N/A	N/A	AUTH_REQUIRED
M09	Sarvam-105B Reasoning	MoE (106B/10B)	N/A	N/A	N/A	N/A	AUTH_REQUIRED
M10	Sarvam-30B Efficient	MoE (32B/2.4B)	N/A	N/A	N/A	N/A	UNAVAILABLE

Investigation of Classification Accuracy: The measured accuracy figures (50.0% to 53.3%) represent genuine multi-class evaluation against controlled legal cases. The key driver of lower nominal accuracy is model abstention. Under strict statutory scrutiny, large reasoning models such as M01 display 100% abstention (classifying cases as INSUFFICIENT_EVIDENCE whenever internal corporate records cannot be observed from public website text). When evaluated on verifiable public notice cases, M03 achieves 66.7% precision on COMPLIANT obligations. Top-3 Majority Voting consensus successfully mitigates individual model abstention bias.

6.3 Parallel Orchestration Wall-Clock Performance

Live execution of the parallel orchestrator across the three accessible models on Groq LPUs confirmed genuine concurrent execution: sequential latency sum = 17,229 ms; actual concurrent wall-clock = 6,938 ms; measured speedup = 2.48x. Verified overlapping timestamps confirm concurrent execution without quota starvation.

7. CONCLUSION

This research presents TrustForge, a fully operational, evidence-grounded compliance assessment framework tailored to the Indian Digital Personal Data Protection Act, 2023 and notified draft DPDP Rules. The research delivers several verified technical contributions:

- **Authoritative Statutory Grounding:** Curated and indexed the authoritative 83-chunk statutory corpus covering the DPDP Act (60 chunks) and Rules (23 chunks).

- **Hybrid RAG Retrieval Relevance:** Resolved marginal-note penalty bleeding (Sections 40/44) via non-normative dampening (0.35x), achieving 84.4% Hit@5 recall.
- **Provider-Aware Parallel Orchestration:** Implemented bounded concurrent execution on Groq LPUs, achieving a 2.48x wall-clock speedup with verified overlapping intervals.
- **Verified Multi-Tenant Security:** Enforced server-side API authorization middleware verifying organization membership on every request, effectively mitigating cross-tenant IDOR vulnerabilities.
- **Scientific Integrity and Defensibility:** Published reproducible benchmarks on 60 controlled test cases, rejecting fabricated accuracy in favor of honest academic evaluation.

Practical Significance & Limitations: TrustForge demonstrates that automated browser automation coupled with grounded hybrid RAG can reliably evaluate public privacy obligations in seconds rather than weeks. Future research will incorporate state-level sectoral circulars (RBI, SEBI) and pursue formal blind peer review of ground-truth datasets with practicing judicial authorities.